DEV-12 · Local Administrator Rights on Endpoints

Who has administrative rights on an organization computer, why the answer should be almost nobody, and how to say yes safely when it must be yes.

Field	Value
Document ID	DEV-12
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	C. Device Usage
Operating tier	Tier 3 — Expert Services designs; Tier 2 applies; Tier 4 approves exceptions.
Review cycle	Every six months.

1. Purpose

This document says who holds administrative rights on an organization endpoint, and how somebody who genuinely needs elevation gets it without holding it permanently.

2. Why this one matters disproportionately

> **Standing local admin is the control that undoes the other controls.**
>
> A user with permanent administrative rights on their machine can — deliberately or by clicking something — disable endpoint protection, stop the management agent, suspend BitLocker, block updates, and install software that does any of those things on their behalf.
>
> Every condition in the DEV-02 baseline sits underneath it. So does the compliance signal Conditional Access reads, which means a compromised machine with local admin can present as healthy.
>
> It is also the most common single factor in ransomware reaching beyond one device.

And it is usually granted for a reason that was good at the time: an application that would not install otherwise, a printer driver, a specialist who needed to move fast years ago. Nobody grants standing local admin carelessly. It accumulates because nothing ever removes it.

3. The standard

	Current state	Target state
Ordinary users	A mixed estate. Some devices carry standing local admin from historical builds and grants.	No standing local administrator rights on any organization endpoint.

	Current state	Target state
IT staff	Administrative work done from separate identities (ACC-07), but local rights may be broadly held.	Elevation on demand from the administrative identity, not standing rights on the user account.
Elevation when needed	Ad hoc — a technician signs in, or rights are granted and left.	A supported elevation mechanism: approved application self-service, or time-boxed elevation with a recorded reason.
The built-in administrator account	Present, and where a common password was ever used across builds, that password is a shared secret across the estate.	Enabled only where required, with a unique password per device, rotated automatically and escrowed centrally (§4).

4. The built-in administrator account

Every Windows device has one. It is the account that matters most and the one least often thought about.

- Where it is enabled, its password must be unique per device, generated automatically, rotated on a schedule and after every use, and stored centrally where an authorised technician can retrieve it.
- A shared local administrator password across an estate means one recovered password grants administrative access to every device it was used on. This is the classic lateral-movement path and it survives reimaging if the same build is reused.
- Retrieval is an account action: verified requester, recorded, and rotated afterwards — the same discipline as a BitLocker recovery key (DEV-03 §7, ACC-06 §2).
- Auditing which devices still carry a legacy shared password is a Tier 3 task and should happen before, not after, the Intune transition completes.

5. When somebody genuinely needs it

Sometimes the answer is yes. The objective is that yes is bounded, recorded and reviewable rather than permanent and forgotten.

Situation	Answer
“I need to install software”	Not local admin. Publish it through the management platform (DEV-11). If it is needed once, a technician installs it. If it is needed often, package it.
A developer or researcher who installs tools constantly	Time-boxed elevation on their own account, or a separate managed development device. A standing grant on a device that also reads their email is the worst of both.
Specialist instrument or lab hardware with vendor software that demands admin	A recorded exception on that device, with a compensating control — network isolation, restricted use, no email or browsing on it.
A senior member of staff who has always had it	Not a technical justification. This is the conversation this document exists to make possible: it is an organization standard rather than an IT preference, and it applies to everyone.

Situation	Answer
An emergency, right now, in front of a class	A technician elevates, does the thing, and removes it. Elevation is a task, not a grant.

Every exception carries: a named holder, the device, the reason, a compensating control, an expiry, and Tier 4 approval. Expiry is not optional — an exception with no end date is a standing grant with paperwork.

6. Removing standing rights from the estate

1. Inventory who currently holds local administrator rights, on which devices. Expect this to be larger than anybody predicts.
2. Sort into: historical grants nobody remembers, grants tied to a specific need, and IT staff.
3. Remove the historical group first. Tell the holders in advance, name what changes, and give them the route to elevation if they hit something. Most will never notice.
4. For need-tied grants, package or publish the underlying application (DEV-11). Removing the need is more durable than removing the right.
5. For IT staff, move elevation to the administrative identity (ACC-07 §3).
6. Convert what genuinely remains into recorded exceptions with expiries.
7. Then add condition 8 to the enforced DEV-02 baseline. Not before — enforcing a condition the estate fails is §2 of DEV-02.

7. Who never gets it

- Temporary workers, in any department (ACC-09 §5).
- Guests and external parties.
- Anybody on a shared, lab, meeting room, kiosk or conference-room device.
- Anybody on a loaner.
- Anybody on a device holding RESTRICTED data (M365-15).

8. Service levels

Activity	Commitment (per GOV-06)
Software installation request	P3 — routed to DEV-11, not answered with elevation.
Technician elevation for a specific task	P2 where the person is blocked; same contact where possible.
Exception request	P3 to Tier 4 — 5 coverage days.
Built-in administrator password retrieval, verified	P2 — 30 minutes.
Quarterly exception review	Tier 4, on schedule.

9. Measurement

- Devices with standing local administrator rights. The number that should be falling.

- Active exceptions, with age and compensating control.
- Elevation events per month — a healthy number, because it means people are using the supported route.
- Devices still carrying a legacy shared built-in administrator password.
- Software requests answered by packaging rather than by elevation.

10. Records

Record	Held in	Retention
Exception register: holder, device, reason, control, expiry, approver	Tier 4 register	Life of exception + 3 years
Elevation events	Management platform log	1 year
Built-in administrator password retrievals	Ticket + platform audit	3 years
Removal programme progress	Project record	Life of programme + 2 years

11. Related documents

ID	Title	Relationship
DEV-02	Device Compliance & Configuration Baseline	Condition 8. Do not enforce before §6 is complete.
DEV-11	Software Request, Approval, Licensing & Deployment	The answer to most requests for local admin.
DEV-01	Device Enrollment & Lifecycle	Exit criterion 10.
DEV-03	Disk Encryption & BitLocker Recovery Keys	Same retrieval discipline for a device secret.
ACC-07	Privileged & Administrative Account Standard	IT elevation from the administrative identity.
ACC-09	Temporary Worker & Departmental Access Standard	§7.
ACC-06	Identity Verification	Before any password retrieval.
M365-15	Data Classification & Handling	RESTRICTED devices, §7.

Appendix A — Exception request card

Field	Required
Who	Named person. Not a role, not a team.
Which device	Asset tag. An exception is per device, never per person across all their devices.
Why	The specific software or task. “Convenience” and “always had it” are not reasons.
Why packaging will not work	Has DEV-11 been tried? Most requests end here.

Field	Required
Compensating control	Network isolation, restricted use, no email or browsing, additional monitoring — something.
Expiry	Required. An exception with no end date is a standing grant with paperwork.
Tier 4 approver	Named.

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.